Informática Forense y Respuesta ante Incidentes

# Tema 8. Análisis forense de dispositivos móviles

# Índice

Esquema

Ideas clave

8.1. Introducción y objetivos

8.2. Peculiaridades de los dispositivos móviles

8.3. Adquisición de dispositivos móviles

8.4. Análisis forense de dispositivos móviles

8.5. Referencias bibliográficas

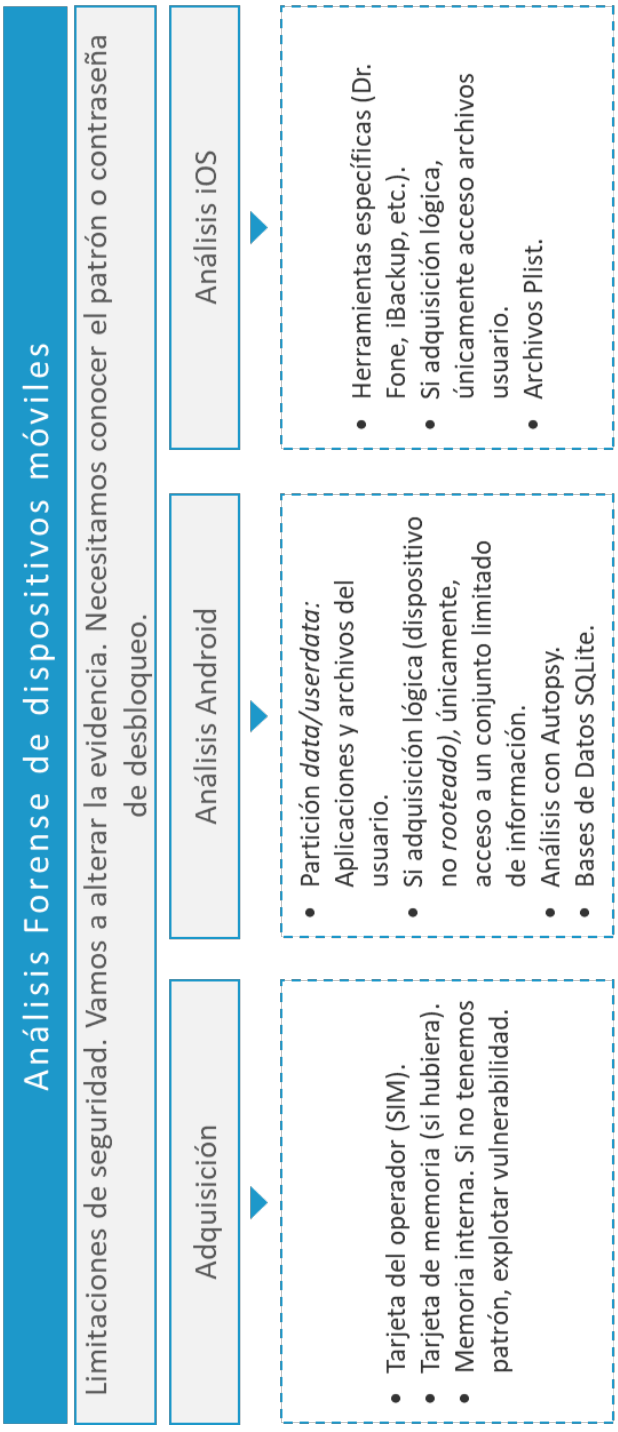
A fondo

DFIR Advanced Smartphone Forensics - Poster

Webinar: An Introduction to Mobile Forensics

Test

# Esquema






© Universidad Internacional de La Rioja (UNIR)

## 8.1. Introducción y objetivos

El uso de dispositivos móviles está ampliamente extendido, por lo que su análisis suele ser relevante en muchos casos.

En este tema se pretende dar una visión general sobre el funcionamiento de este tipo de dispositivos y ver cómo podemos adquirir y analizar la información que contienen.

Debemos tener en cuenta que estos dispositivos (teléfonos móviles, *smartwatch,* etc.) implementan una serie de protecciones que nos van a dificultar enormemente su análisis, por lo que no siempre podremos obtener de ellos la información que buscamos.

Al igual que en temas anteriores, en este tema no se pretende abarcar todos los posibles análisis a los que nos podemos enfrentar, sino que se expone cuáles son las fuentes de información más típicas y cómo podemos adquirir y analizar este tipo de dispositivos.

Los objetivos de este tema son:

- Conocer las **peculiaridades de los dispositivos móviles** y por qué su análisis implica una serie de dificultades adicionales.
- Saber cuáles son las **fuentes de información** que nos podemos encontrar cuando analizamos un dispositivo móvil.
- Conocer cómo podemos **realizar la adquisición de la información** contenida en un dispositivo móvil.
- Conocer qué **técnicas y herramientas** podemos aplicar para analizar la información adquirida de un dispositivo móvil.


© Universidad Internacional de La Rioja (UNIR)

## 8.2. Peculiaridades de los dispositivos móviles

El procedimiento de adquisición y análisis de dispositivos móviles como teléfonos, tabletas o *smartwatch* es muy distinto del utilizado para equipos informáticos y servidores.

Si en Informática Forense la máxima era no modificar la evidencia y su protección contra escritura, en Telefonía Forense esta máxima no aplica, ya que es imposible realizar la adquisición de un dispositivo móvil sin alterar su contenido.

Esto hace que todo el proceso de adquisición y análisis varíe, y que tengamos que aplicar técnicas específicas que nos permitan obtener y analizar la información de interés.

El principal problema al que nos enfrentamos cuando queremos realizar la adquisición de un dispositivo móvil son las **limitaciones de seguridad.**

En un teléfono móvil, en una tableta o en un *smartwatch* no tenemos acceso completo a la memoria, lo que nos va a impedir (en la mayoría de los casos) realizar una adquisición completa tal y como haríamos con el disco duro de un ordenador.

Salvo en aquellos casos en los que el dispositivo esté rooteado o podamos rootearlo (si se puede y es necesario para afrontar con garantías la pericial, debemos solicitar permiso expreso al juez o al usuario propietario), la única información que nos vamos a llevar va a ser la que esté disponible al usuario, nada de archivos borrados (podremos recuperar algunos archivos, pero no podremos recuperar archivos en bruto) o archivos a los que únicamente puede acceder el sistema.

Otro problema con el que nos vamos a encontrar a la hora de realizar la adquisición y


© Universidad Internacional de La Rioja (UNIR)

análisis de este tipo de dispositivos es el **sistema de bloqueo del terminal.**

Cuando vamos a adquirir un dispositivo móvil, salvo que aprovechemos vulnerabilidades conocidas o utilicemos herramientas comerciales que exploten estas vulnerabilidades, si no conocemos el patrón de desbloqueo (PIN, contraseña, etc.), no vamos a poder realizar la adquisición.

Todos estos inconvenientes limitan enormemente nuestras posibilidades a la hora de afrontar con garantías una pericial. Aun así, veremos que, según qué escenario tengamos, quizá podamos llevar a cabo (con las garantías suficientes) el análisis forense.


© Universidad Internacional de La Rioja (UNIR)

## 8.3. Adquisición de dispositivos móviles

**Procedimiento de adquisición**

Cuando vamos a realizar la adquisición de un dispositivo móvil, el procedimiento a seguir es el siguiente:

- 1. Adquirir la tarjeta del operador (Tarjeta SIM).
- 2. Adquirir la tarjeta de memoria.
- 3. Adquirir la memoria del terminal.
  - a. Si tenemos patrón: mediante herramientas de adquisición como Magnet Acquire o las propias herramientas de *backup* del fabricante.
  - b. Si no tenemos patrón: intentando explotar alguna vulnerabilidad conocida o utilizando herramientas comerciales que lo permitan.

### La tarjeta del operador

**Introducción**

La tarjeta de operador o tarjeta SIM tiene las siguientes particularidades:

- Poca capacidad de almacenamiento de información.
- Puede contener contactos, registro de llamadas o SMS (cada vez más, los dispositivos móviles almacenan esta información en la memoria del dispositivo en lugar de hacerlo en la tarjeta).
- No contiene datos multimedia (fotos, audio, vídeo, etc.).
- Podemos obtener los códigos ICCID (identifica la propia tarjeta) y el IMSI (identifica la línea).


© Universidad Internacional de La Rioja (UNIR)

# Ideas clave

A nivel lógico, la información de la tarjeta SIM se estructura de manera «similar» a un dispositivo de almacenamiento con archivos y carpetas.

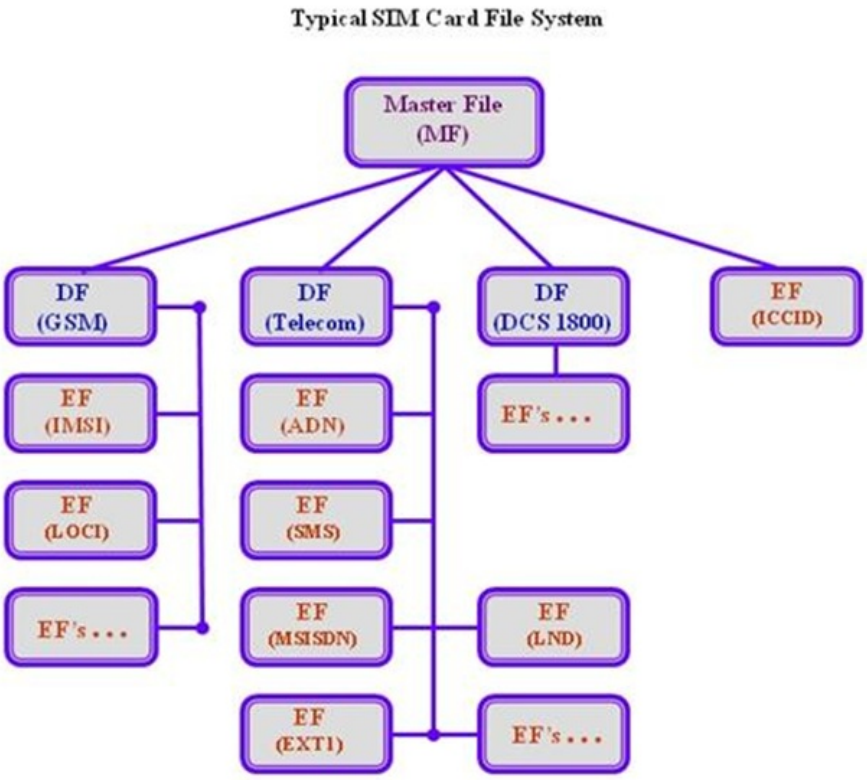



Figura 1. Estructura del Sistema de Ficheros de una tarjeta SIM. Fuente: https://resources.infosecinstitute.com/topic/sim-card-forensics-introduction/.

El sistema de ficheros de una tarjeta SIM comienza con el Master File (MF), la raíz del sistema de ficheros, algo así como el *root directory* en un FAT, de donde cuelgan los distintos DF (Dedicated File), que serían algo así como subdirectorios especializados en aspectos concretos y los EF (Elementary Files), donde se almacena la información. Vamos a ver ahora los archivos más importantes:

- DF (GSM)/ DF (DCS 1800): contiene la aplicación GSM.
- DF (Telecom): almacena información relacionada con los servicios que ofrece la operadora; EF (ADN), la agenda; EF (SMS), los mensajes SMS; EF (MSISDN), el


© Universidad Internacional de La Rioja (UNIR)

número asociado al abonado, etc.

- EF (ICCID): identificador de la tarjeta del circuito integrado.
- EF (IMSI): identidad internacional de abonado móvil.
- EF (LND): últimos números marcados.

**Adquisición**

Para adquirir la tarjeta de operador (SIM) necesitaremos:

- Un lector de tarjetas SIM.
- Un *software* de adquisición (simcon, SIM Explorer, etc.).
- El PIN y/o PUK de la tarjeta. Sin este dato no podremos acceder.




Figura 2. Elementos necesarios para la adquisición de la tarjeta SIM. Fuente: elaboración propia.

El procedimiento de adquisición es similar a la adquisición de cualquier otro dispositivo externo, como puede ser un *pendrive,* con la salvedad del *software* empleado.

Antes de comenzar el proceso de adquisición, la herramienta que utilicemos nos solicitará el código PIN o PUK con el cual desbloquear la tarjeta SIM, ya que sin ese código es imposible acceder al contenido de esta.

Cuando adquiramos o analicemos la información de una tarjeta SIM, debemos tener en cuenta que muchos de los datos que veremos son registros de comunicación con las antenas de telefonía y que interpretar dicha información no es tarea sencilla, por


© Universidad Internacional de La Rioja (UNIR)

lo que es recomendable **solicitarlos a la operadora a través de la autoridad judicial.**

**eSIM**

> Una eSIM o SIM Virtual o embebida es una evolución de la tarjeta SIM que integra el chip de estas en el propio *hardware* del dispositivo. De esta forma se elimina la necesidad de introducir físicamente la tarjeta o de cambiarla por una nueva cuando cambiamos de operador.

Una eSIM no puede ser adquirida como tal, ya que no almacena información como la que podemos llegar a obtener de una tarjeta SIM clásica, si no que, únicamente, mantiene el ICCID que la identifica.

## La tarjeta de memoria

**Introducción**

Aunque no todos los dispositivos móviles hacen uso de tarjetas de memoria, como pueden ser las típicas tarjetas microSD, si el dispositivo que estamos estudiando dispone de este tipo de tarjetas debemos analizarla.

Las tarjetas de memoria externas suelen contener una gran cantidad de información entre la que podemos encontrar:

- Archivos multimedia (fotografías, vídeos, música, etc.).
- APKs instaladas por el usuario.
- Descargas.
- Bases de datos.
- Cachés o registros de aplicaciones.


© Universidad Internacional de La Rioja (UNIR)

- Etc.

**Adquisición**

Para adquirir la tarjeta de almacenamiento necesitaremos:

- **Un lector de tarjetas**
  - a. Si tiene bloqueo contra escritura por *hardware,* mucho mejor.
  - b. Si no tiene bloque contra escritura, utilizaremos algún sistema de bloqueo por *software.*
- Un *software* de adquisición como FTK Imager, dc3dd, etc.

El procedimiento de adquisición de una tarjeta de memoria es el mismo que el utilizado para la adquisición de un *pendrive,* el cual se encuadra dentro de los procedimientos especiales de adquisición definidos en la ISO 27037.

## El dispositivo móvil

**Introducción**

La adquisición del terminal consiste en la adquisición de su memoria interna. Los dispositivos móviles cada vez tienen memorias internas de mayor capacidad, por lo que la cantidad de información que podemos obtener de ellos también es cada vez mayor.

Ahora bien, dadas las limitaciones de seguridad, en muchas ocasiones lo único que vamos a poder adquirir es la parte de la memoria que se encuentra disponible para el usuario, siempre y cuando tengamos acceso al terminal (patrón, contraseña, etc.).

**Adquisición**

Para adquirir la memoria interna del terminal tenemos varias opciones:


© Universidad Internacional de La Rioja (UNIR)

# Ideas clave

- 1. **Utilizar la propia suite de *backup* del fabricante.** Nos permite adquirir rápidamente la información más básica.
- 2. **Adquisición mediante Magnet Acquire.** Sencilla como la adquisición mediante *backup*, pero obteniendo más información.
- 3. **Adquisición lógica de un dispositivo iOS.** Sencilla como la adquisición mediante *backup,* pero utilizando herramientas específicas de forense.
- 4. **Adquisición mediante ADB (Android únicamente).** Si conseguimos acceso privilegiado, nos permite adquirir toda la memoria.
- 5. **Adquisición mediante Custom Recovery** (Android únicamente). Si conseguimos acceso privilegiado, nos permite adquirir toda la memoria.
- 6. **Métodos avanzados de adquisición:** Jtag, Direct eMMC y ChipOff.

De las opciones indicadas, las más sencillas serían la adquisición de *backup* utilizando la propia *suite* del fabricante o la adquisición mediante herramientas como Magnet. Acquire u alguna otra específica para iOS.

Debemos tener en cuenta que, en ambos casos, vamos a necesitar conocer la **contraseña o patrón de desbloqueo** para poder realizar la adquisición.

L a s **adquisiciones mediante ADB o Custom Recovery,** ambas únicamente disponibles en Android, nos permitirían obtener más información si conseguimos acceso privilegiado al terminal, pero dados los continuos cambios y las continuas mejoras en la seguridad de los dispositivos móviles, este tipo de adquisiciones es cada vez más complejas, y es más complicado que las podamos realizar.

Por último, las adquisiciones mediante Jtag, Direct eMMC o ChipOff nos permiten adquirir directamente la memoria de los terminales, pero requieren de amplios conocimientos tanto a nivel electrónico como de micro soldadura, por lo que suelen ser realizadas por empresas externas especializadas.


© Universidad Internacional de La Rioja (UNIR)

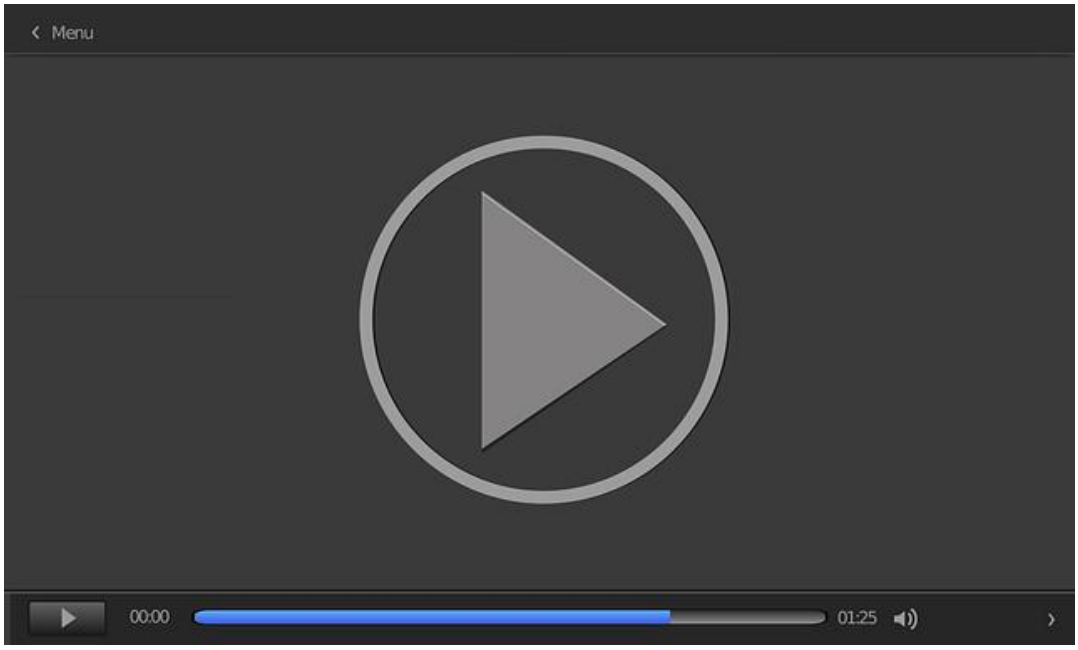
**Adquisición mediante la suite de *backup* del fabricante**

Se trata del tipo de adquisición más sencillo. Nos permite acceder a información básica, pero muy útil como archivos multimedia, registro de llamadas, contactos, etc.

También podremos acceder a las conversaciones de algunos programas de mensajería como WhatsApp y a correos electrónicos o notas de voz.

Por un lado, si el terminal a adquirir es un Android, podremos analizar su información con cualquier herramienta de análisis forense como Autopsy. Por otro lado, si el terminal a adquirir es un iPhone, debemos hacer uso de herramientas específicas como Dr. Fone o iBackup Viewer.

En el siguiente vídeo, hablaremos sobe iBackup Viewer, utilizada para el análisis de backups de dispositivos iOS:




Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=693bf807-1ca0-4f9e-aab5-b19c00ba30d4



© Universidad Internacional de La Rioja (UNIR)

Hay que tener en cuenta que cada *suite* de *backup* puede almacenar la copia de respaldo en una ubicación u otra, por lo que deberemos comprobar dónde se encuentra dicha información.

A modo de ejemplo:

- iTunes (PC):
  - Users\[Usuario]\AppData\Roaming\Apple Computer\ MobileSync\Backup\.
  - Users\[Usuario]\Apple\MobileSync\Backup.
- iTunes (MacOS):
  - ~/Library/Application Support/MobileSync/Backup.

Para realizar una adquisición lógica de la información más elemental de un terminal, utilizando las suites de *backup* de los fabricantes seguiremos los siguientes pasos:

- 1. Extraeremos la tarjeta de almacenamiento y la SIM.
- 2. Pondremos el terminal en modo avión (si no lo hemos hecho durante la recolección y no disponemos de inhibidores de frecuencia).
- 3. No bloquearemos la escritura de los puertos USB (este tipo de adquisición puede alterar la evidencia).
- 4. El teléfono debe estar encendido y desbloqueado.
- 5. Modo de transferencia de datos multimedia (MTP) activo.
- 6. Ejecutaremos el procedimiento de backup de la suite del fabricante.

**Adquisición mediante Magnet ACQUIRE**

El procedimiento de adquisición mediante el uso de alguna herramienta como


© Universidad Internacional de La Rioja (UNIR)

# Ideas clave

Magnet ACQUIRE es de los más sencillos y también de los más utilizados cuando vamos a trabajar con un dispositivo del cual tenemos el patrón o contraseña de desbloqueo.

Los pasos a realizar son similares a la adquisición mediante la *suite* del fabricante, y es que, para realizar la adquisición mediante la herramienta forense Magnet ACQUIRE, vamos a necesitar que el teléfono se encuentre **desbloqueado y con la depuración por USB activada.** Esto permitirá que la aplicación reconozca el terminal y lo adquiera.

En Magnet ACQUIRE podemos realizar **dos tipos de adquisiciones: rápida y completa.** Si somos *root* (el dispositivo se encontraba *rooteado* o hemos conseguido ser *root* mediante la explotación de alguna vulnerabilidad), en el dispositivo tendremos la posibilidad de realizar una adquisición completa de la información; sin embargo, si no lo somos, únicamente nos quedará la opción de adquisición rápida.

Una vez finalizado el proceso de adquisición con Magnet ACQUIRE, al tratarse de una herramienta de uso forense, la propia utilidad nos calcula los *hashes* de la información, y nos genera una serie de *logs* de los procesos realizados.

**Adquisición lógica de un dispositivo iOS**

Un dispositivo iOS lo podemos adquirir utilizando la propia herramienta de *backup* de iTunes, con herramientas como Magnet ACQUIRE o con algunas otras más específicas como Dr. Fone.

La ventaja de utilizar herramientas específicas como Dr. Fone es que se centran en la información que, generalmente, vamos a necesitar, y nos simplifican todo el proceso de adquisición y tratamiento de esta.

Aunque Dr. Fone es una herramienta comercial, su coste (bastante accesible) y


© Universidad Internacional de La Rioja (UNIR)

facilidad de uso la hacen bastante interesante para iniciarse en el mundo del análisis forense de dispositivos móviles.

Dr. Fone incluye diversas herramientas para el tratamiento de teléfonos móviles: recuperación, respaldo y restauración, transferencia de archivos, etc. De todas ellas, la que nos interesa es la de **recuperación de información.**

El primer paso consiste en conectar el terminal al equipo. Es posible que tengamos que introducir el código de desbloqueo del teléfono y aceptar la solicitud de confianza con el ordenador.

La herramienta de recuperación nos permite obtener: mensajes, contactos, historial de llamadas, notas, calendario, Whatsapp, Viber, marcadores de Safar y otra información de interés incluidos archivos eliminados (si es posible su recuperación).

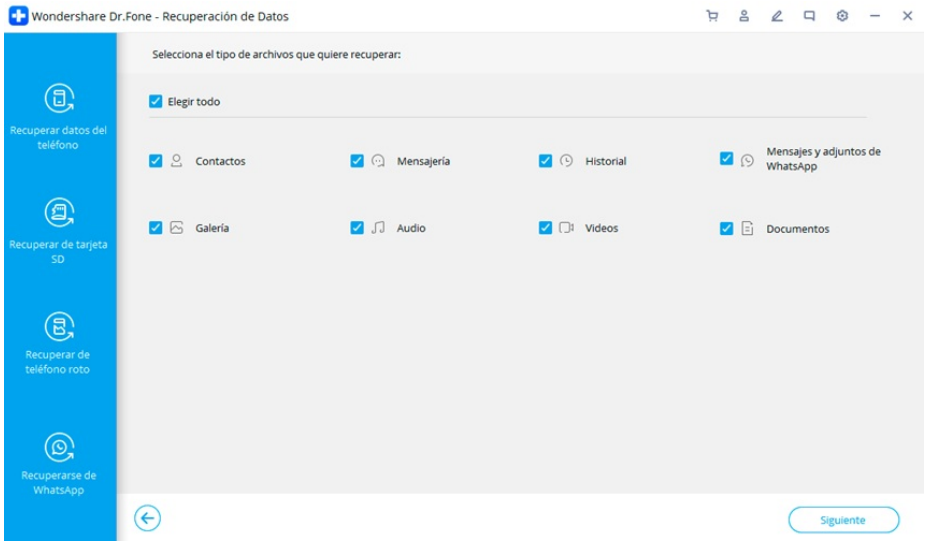



Figura 3. Interfaz Dr. Fone. Fuente: elaboración propia.

Una vez seleccionadas las opciones de recuperación que queremos, tan solo debemos pulsar sobre «Iniciar escaneo» para que comience el proceso de búsqueda de información dentro del teléfono.

Cuando finalice el proceso, podremos ver en el menú de la izquierda toda la


© Universidad Internacional de La Rioja (UNIR)

información encontrada. Si seleccionamos una categoría, en la parte derecha veremos qué información almacena el teléfono.

Entre toda la información que Dr. Fone es capaz de obtener, un punto muy importante es la relacionada con la mensajería instantánea como Whatsapp, Viber o KIK, donde no solo vamos a obtener los mensajes intercambiados, tenemos acceso a los adjuntos enviados y recibidos en estas aplicaciones de mensajería.

**Adquisición mediante ADB**

La adquisición mediante ADB es un paso más en el proceso de obtención de información de un terminal móvil.

Para realizar la adquisición mediante ADB es necesario:

- 1. Que el equipo tenga los drivers ADB necesarios.
- 2. Que el equipo tenga instaladas las Android SDK Platform Tools.
- 3. Que el terminal tenga habilitada la depuración por USB.
- 4. Que seamos *root* en el terminal.
- 5. La aplicación *busybox* instalada en el dispositivo (nos da acceso a una Shell más completa que implementa el comando DD).

Ser *root* en el terminal puede ser un arma de doble filo, por lo que lo más recomendable es solicitar permiso expreso al juez indicando que lo único que vamos a hacer es escalar privilegios para realizar la adquisición de la memoria del terminal. Esto es muy importante ya que se trata de una acción potencialmente dañina para la evidencia.

Además, para realizar la adquisición mediante ADB también es necesario:

- 1. Conocer que las **estructuras** que nos interesan se encuentran bajo la carpeta


© Universidad Internacional de La Rioja (UNIR)

/dev del sistema de ficheros.

- 2. Saber que las **particiones** suelen nombrarse de la siguiente forma: mmcmlkp0, mmcmlkp1, …, mmcmlkpN.
- 3. Saber que los **bloques** suelen nombrarse de la siguiente manera: mmcblk0, mmcblk1, …, mmcblkN.
- 4. Saber que un bloque puede englobar varias particiones (y, de hecho, lo hace).
- 5. Disponer de un **soporte de salida,** un lugar para almacenar la copia. Normalmente, utilizaremos una microSD (borrada de forma segura) conectada al teléfono móvil, aunque también podemos utilizar «netcat» mediante línea de comandos.

Una vez todo listo: *drivers,* herramientas de consola de comandos, teléfono rooteado, modo depuración activo y *busybox* instalado, comenzaremos la adquisición.

Para ello, el primer paso es listar los dispositivos conectados por adb mediante el comando «adb devices».

Una vez tenemos el listado de dispositivos, abriremos una shell como superusuario mediante el comando: «adb shell /su».

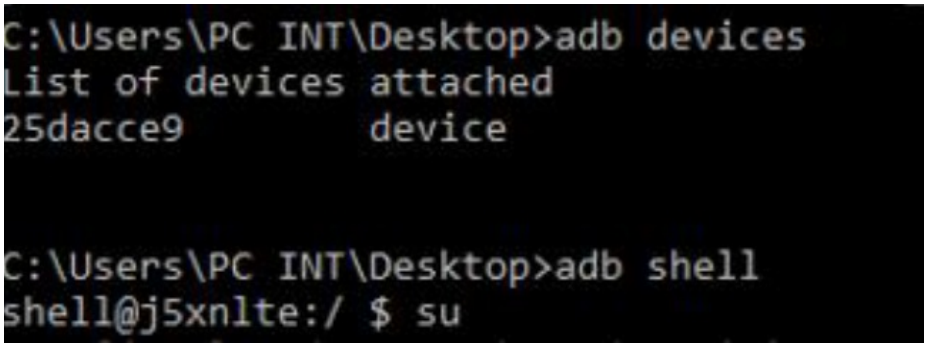



Figura 4. Comandos adb. Fuente: elaboración propia.

Tras la ejecución de este comando, estaremos como superusuario dentro del


© Universidad Internacional de La Rioja (UNIR)

dispositivo, por lo que procederemos a listas las particiones y bloques de este mediante el comando: «cat /proc/partitions».

Cuando sepamos qué partición o bloque queremos adquirir, ejecutaremos el comando «dd» para realizar la adquisición de la información. Por ejemplo:

dd if=/dev/block/mmcblk0 of=/storage/307D-X/imagen.dd

En el ejemplo anterior estamos adquiriendo el bloque 0 (if=/dev/block/mmcblk0), y lo estamos guardando dentro de la tarjeta de memoria conectada al dispositivo en un archivo que hemos nombrado como imagen.dd (of=/storage/307D-X/imagen.dd).

A la finalización del proceso, obtendremos un resumen de la información leída, copiada y los bytes transferidos.

**Adquisición mediante Custom Recovery**

La adquisición mediante «Custom Recovery» se basa en modificar la partición de recuperación del dispositivo e instalar en ella una distribución específica que nos permita adquirir la información de este.

Para la adquisición mediante Custom Recovery debemos tener en cuenta:

- 1. Estamos sustituyendo la partición de recuperación del terminal *(recovery).*
- 2. Cada terminal funciona de una manera. Lo que es aplicable a una marca, no tiene por qué serlo para otra.
- 3. Ha de estar desbloqueado el *bootloader.* Si no lo está, al desbloquearlo se suelen restaurar los ajustes de fábrica y eliminar por completo el contenido del dispositivo.
- 4. No es necesario conocer el código de bloqueo del terminal (aunque es posible que el contenido que leamos esté cifrado).
- 5. Es una operación potencialmente dañina que requiere de experiencia y destreza,


© Universidad Internacional de La Rioja (UNIR)

además de autorización judicial.

Para la adquisición mediante Custom Recovery, necesitamos además una serie de herramientas:

- 1. *Drivers* del terminal (Samsung, HTC, etc.).
- 2. Una herramienta de *flasheo* específica para el modelo de terminal (por ejemplo, Odín para dispositivos Samsung).
- 3. El Custom Recovery específico para el terminal, normalmente va a ser un Custom Recovery TWRP (Team Win Recovery Project).
- 4. Una tarjeta microSD o un Pendrive (si el terminal tiene soporte OTG) para almacenar el volcado.

El procedimiento de instalación del Custom Recovery varía en función del dispositivo, pero, generalmente, consiste en:

- 1. Reiniciar el dispositivo en modo descarga.
- 2. Iniciar el *software* de *flasheo* en el equipo al que se encuentre conectado el terminal.
- 3. Cargar el Custom Recovery en la partición de recuperación del dispositivo.

Una vez instalado el Custom Recovery, reiniciamos el terminal en modo recuperación, lo que nos debería mostrar el interfaz del Custom Recovery instalado.


© Universidad Internacional de La Rioja (UNIR)

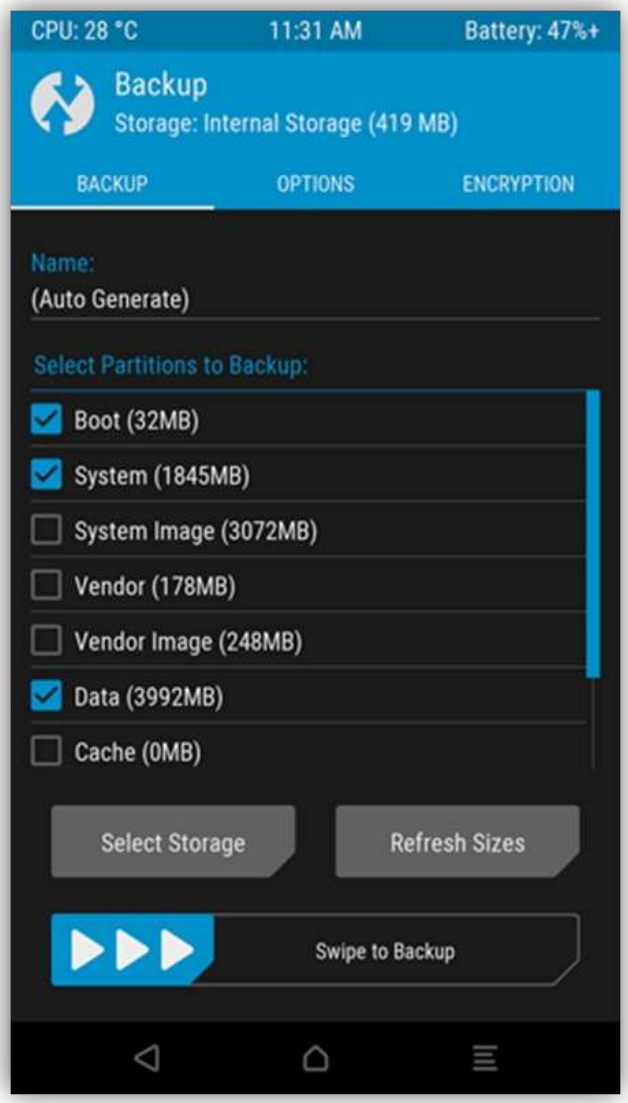



Figura 5. Interfaz TWRP. Fuente: elaboración propia.

Desde la interfaz del Custom Recovery, tendremos que montar las particiones sobre las que vamos a trabajar y adquirir mediante el comando «dd» estas particiones a un archivo que almacenaremos en la tarjeta de memoria o en un pendrive conectado al teléfono.

**Métodos avanzados de adquisición**



© Universidad Internacional de La Rioja (UNIR)

Se consideran métodos avanzados de adquisición las técnicas que hacen uso de procedimientos que permiten el acceso a bajo nivel a la información contenida en los chips de memoria del dispositivo.

Las **técnicas** más comúnmente utilizadas son: **Jtag, Direct eMMC y Chip Off.** Estas técnicas de adquisición son técnicas invasivas y pueden dejar inservible el indicio. Por lo tanto, como siempre decimos, es necesario el auto judicial donde se nos autorice su uso.

En el auto debemos hacer mención a las técnicas que vamos a emplear (en principio, las tres, ya que no sabemos *a priori* cuál de ellas nos va a dar el resultado esperado) y a su peligrosidad, indicando que es posible la pérdida total de la memoria del indicio.

**JTAG**

JTAG es el acrónimo de Joint Test Action Group (Grupo Mixto de Acción de Pruebas), un estándar utilizado para comprobar el funcionamiento de placas de circuito impreso.

Cuando se ha fabricado la placa base (ejemplo, la de un teléfono móvil), antes de continuar con el proceso de montaje, se verifica que funciona correctamente haciendo uso de unos contactos (TAGs).

Haciendo uso de este estándar, podemos acceder a la memoria y realizar un volcado de esta como si de una puerta trasera se tratara.

Es la técnica menos lesiva, ya que no implica una gran alteración del indicio, pero son necesarios conocimientos de micro soldadura.

Uno de los grandes inconvenientes de este método es su **limitada velocidad.** Al poseer una única línea de datos, el protocolo es necesariamente serie, lo que limita


© Universidad Internacional de La Rioja (UNIR)

en gran medida su velocidad.

A modo de ejemplo, con un terminal de 32Gb de memoria, podemos estar hasta 24h para obtener un volcado completo de su memoria.

**Direct eMMC**

El método conocido como Direct eMMC —en ocasiones, nombrado como ISP (In-System Programming)— nos va a permitir realizar la adquisición de este tipo de memorias (incluidas las eMCP) sin necesidad de extraerlas, utilizando unos conectores auxiliares distribuidos por la PCB.

Estos conectores, similares a los TAGs del procedimiento anterior, son muy diminutos, por lo que las posibilidades de dañar la placa durante el proceso son muy elevadas.

La principal ventaja de este método es la posibilidad de comunicarse con el chip de memoria sin pasar por la CPU.

Ofrece una mayor velocidad para la extracción de datos en comparación con JTAG, pero requiere grandes habilidades de soldadura.

**Chip Off**

El Chip Off es la técnica más destructiva de las tres, ya que consiste en la extracción física del chip de memoria para su lectura directa mediante dispositivos específicos.

Lo utilizaremos siempre que los métodos anteriores no sean posibles (dispositivos dañados, principalmente).


© Universidad Internacional de La Rioja (UNIR)

# Ideas clave

Esta técnica requiere de gran destreza y conocimientos tanto de las memorias como de micro soldadura para evitar la destrucción de la evidencia.


© Universidad Internacional de La Rioja (UNIR)

## 8.4. Análisis forense de dispositivos móviles

**Análisis forense de dispositivos Android**

Una vez hemos realizado la adquisición de la información contenida en un dispositivo Android, debemos proceder a su análisis.

El Sistema Operativo Android está basado en Linux, por lo que su análisis es muy similar al de un equipo con Sistema Operativo Linux con la salvedad de las aplicaciones y las bases de datos específicas utilizadas para almacenar información sobre el dispositivo.

Si hemos conseguido realizar la adquisición física del dispositivo, tendremos acceso a todas las particiones de este. En función de la versión concreta del sistema operativo, es posible que las particiones varíen, pero las más relevantes suelen ser:

- *boot:* contiene los *drivers,* el kernel del SO y otros archivos necesarios para el arranque.
- *system:* contiene los archivos del sistema operativo instalado.
- *recovery:* partición de recuperación. Contiene un «mini sistema operativo» independiente del principal que es el encargado de iniciar el dispositivo en modo recuperación.
- *cache:* almacena datos temporales necesarios para la actualización del sistema operativo. Si el dispositivo soporta actualizaciones A/B, esta partición es opcional.
- *data/userdata:* contiene las aplicaciones y archivos del usuario. Generalmente, es la de mayor interés forense.

Si hemos realizado una adquisición lógica, únicamente tendremos acceso a un limitado conjunto de archivos y carpetas donde encontraremos archivos multimedia,


© Universidad Internacional de La Rioja (UNIR)

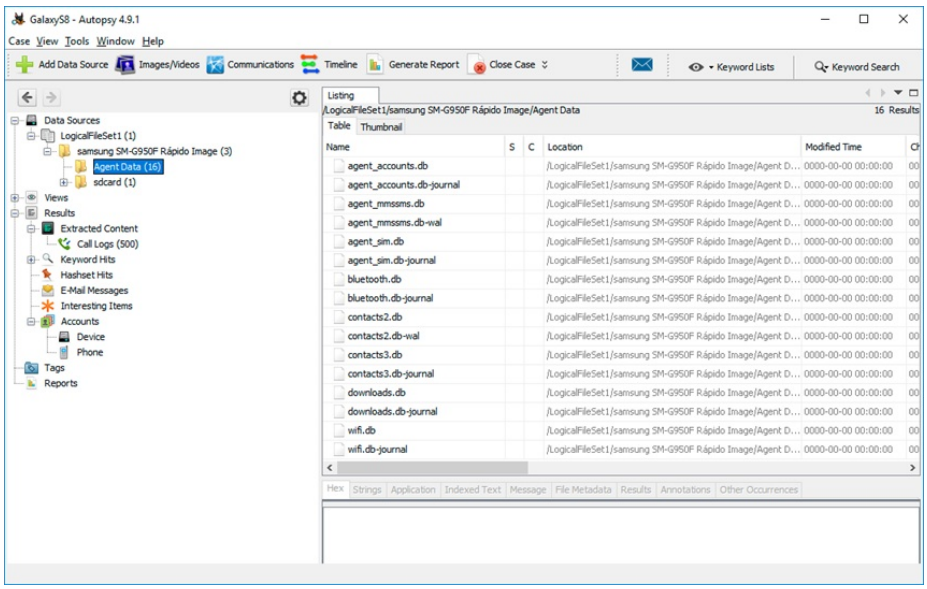
configuraciones de las aplicaciones y algunas bases de datos.

**Análisis de la imagen forense con Autopsy**

La imagen forense que hemos generado con Magnet Acquire puede ser fácilmente analizada con Autopsy. Para ello, tan solo tenemos que seguir unos sencillos pasos:

- 1. Creamos un nuevo caso en Autopsy.
- 2. Añadimos el contenido de la imagen forense generada (En el caso de Magnet Acquire, descomprimiendo el archivo.ZIP generado y añadiendo también la carpeta «Agent Data»).
- 3. Seleccionamos en Autopsy los plugins que queremos aplicar. Al menos, debemos seleccionar el denominado «Android Analyzer».
- 4. La información obtenida por el *plugin* «Android Analyzer» y la extraída por el propio Magnet Acquire (la cual se encuentra en la carpeta «Agent Data») nos van a facilitar enormemente todo el proceso de análisis.

Cuando finalice la ejecución del *plugin* podremos ver, en el menú de resultados, toda la información que Autopsy ha podido extraer del dispositivo.






© Universidad Internacional de La Rioja (UNIR)

Figura 6. Interfaz Autopsy. Fuente: elaboración propia.

La información que podemos obtener (principalmente de las bases de datos generadas por el agente de Magnet Acquire) es:

- agent_accounts.db: cuentas del usuario (Google, Whatsapp, etc.).
- agent_mmssms.db: mensajes de texto y mensajes multimedia (MMS).
- agent_sim.db: información de la SIM (IMEI, IMSI, ICCD, nº de teléfono, etc.).
- bluetooth.db: dispositivos bluetooth con los que se encuentra enlazado el terminal.
- contactsX.db: contactos, inc. teléfonos, direcciones, historial de llamadas, etc.
- downloads.db: archivos descargados por el usuario y la ruta de descarga.
- wifi.db: redes Wifi recordadas por el terminal.

Además de la información que podemos obtener de estas bases de datos, Magnet Acquire también adquiere el espacio de almacenamiento del teléfono (similar a lo que se obtiene de la tarjeta microSD) y los datos de las aplicaciones.

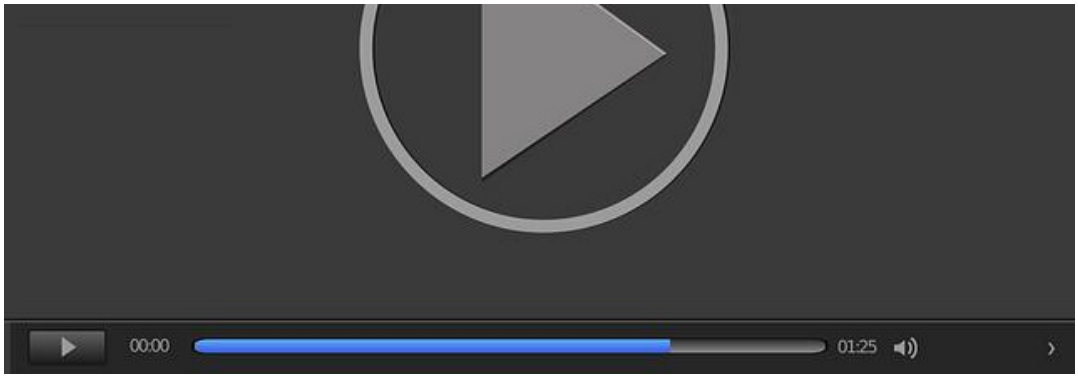
En este espacio es donde podemos encontrar las copias de seguridad de WhatsApp, cifradas (puede variar en función de la versión del programa o, incluso, no aparecer). También podemos obtener archivos de preferencias de las aplicaciones con información muy valiosa.

En el siguiente vídeo, hablaremos sobre la herramienta Autopsy:





© Universidad Internacional de La Rioja (UNIR)




Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=520d20a6-9ada-414c-9cf1-b19c00b8dc35

**Análisis de las bases de datos**

Las Bases de Datos más interesantes de las aplicaciones de un terminal Android, desde un punto de vista forense son:

- Notas:
  - Userdata/Root/data/com.samsung.android.app.memo/databases/memo.d
- Contactos
  - Userdata/Root/data/com.android.providers.contacts/databases/contacts2.db
- Calendario
  - Userdata/Root/data/com.android.providers.calendar/databases/calendar.db
- Correo electrónico
  - Userdata/Root/data/com.samsung.android.email.provider/databases/EmailProvider.db
- Historial de navegación (Google Chrome)



© Universidad Internacional de La Rioja (UNIR)

- Userdata/Root/data/com.android.chrome/app_chrome/Default/History

- Historial de navegación (Navegador por defecto)
  - Userdata/Root/data/com.android.browser/databases/browser2.db
- Mensajes de texto*
  - Userdata/Root/data/com.android.providers.telephony/databases/mmssms.db
- Registro de llamadas*
  - Userdata/Root/data/com.android.providers.contacts/databases/contacts2.db

Es posible que algunas de estas bases de datos no se hayan adquirido durante una adquisición lógica.

**Análisis Forense de dispositivos iOS**

Una vez hemos realizado la adquisición de la información contenida en un dispositivo iOS, debemos proceder a su análisis. A nivel interno, la estructura de particiones en Sistemas Operativos iOS es bastante diferente de la utilizada en sistemas Android.


© Universidad Internacional de La Rioja (UNIR)

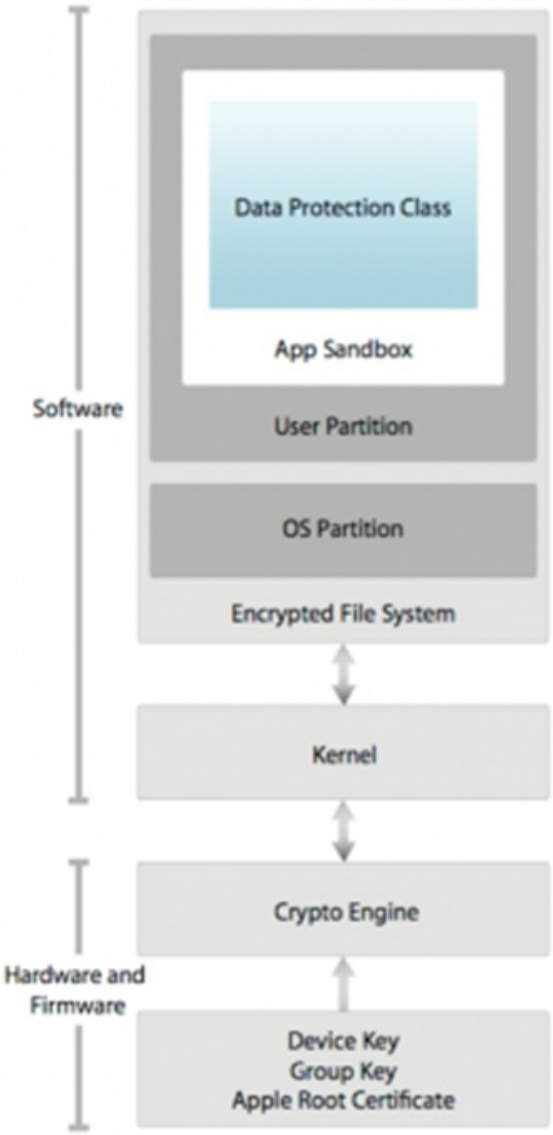



Figura 7. Estructura interna iOS. Documentación oficial.

La estructura interna de los dispositivos iOS suele organizarse de manera similar a la de la imagen.

Existen dos **particiones: de usuario y de sistema** las cuales se encuentran cifradas. A su vez, las aplicaciones de usuario se ejecutan dentro de una Sandbox, lo que impide que puedan acceder a otras aplicaciones o datos para los que no tienen permiso.



© Universidad Internacional de La Rioja (UNIR)

Todo esto unido a los distintos sistemas de cifrado y seguridad, hace que la manera más viable para la adquisición de la información de un Teléfono con iOS sea mediante una copia de seguridad o adquisición lógica de la información del usuario.

El análisis forense de un dispositivo iOS suele realizarse con herramientas específicas que nos permitan interpretar la información del volcado realizado, aunque también es posible realizar el análisis de manera «manual».

Algunas de las herramientas que podemos utilizar para analizar un volcado de un dispositivo iOS son: **Dr. Fone y iBackup Viewer.**

El funcionamiento de ambas es bastante similar, ya que lo único que debemos hacer es seleccionar el *backup* realizado mediante iTunes o Magnet Acquire, y la herramienta automáticamente lo procesa y nos muestra la información.

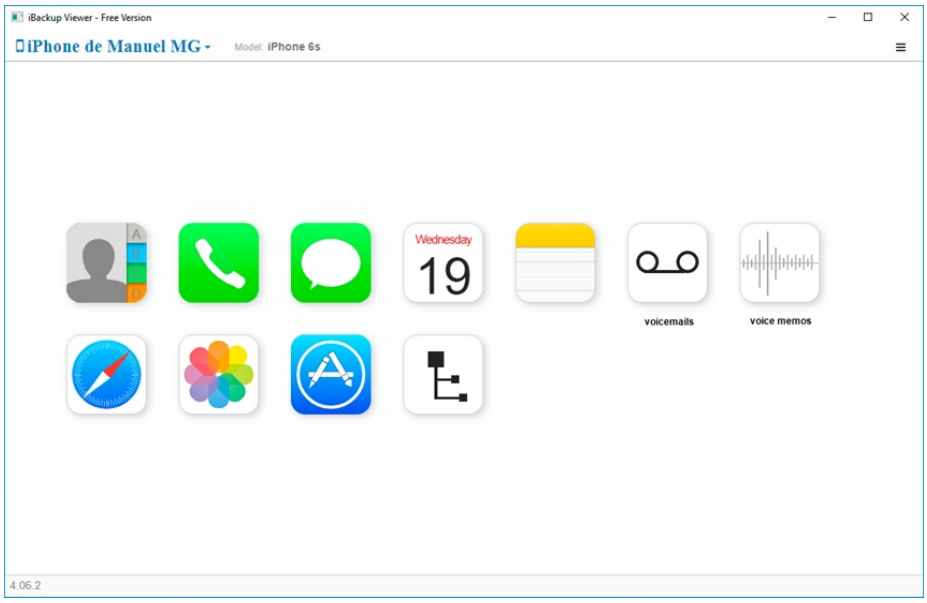



Figura 8. Interfaz iBackup Viewer. Fuente: elaboración propia.

Como podemos ver en la imagen, la herramienta nos permite acceder de manera muy directa a la distinta información contenida en la copia de seguridad como son los contactos, historial de mensajes y llamadas, aplicaciones, etc.


© Universidad Internacional de La Rioja (UNIR)

Además, también nos permite el acceso al sistema de ficheros para poder visualizar los distintos archivos que gestionan las aplicaciones instaladas, archivos.PLIST o bases de datos SQLite, entre otros.

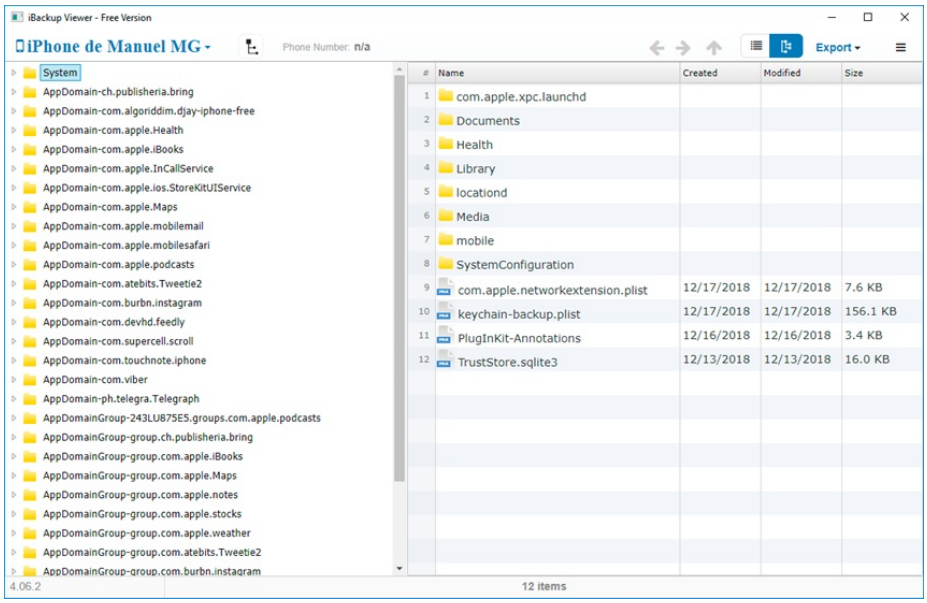



Figura 9. Sistema de Ficheros iBackup Viewer. Fuente: elaboración propia.

Las Bases de Datos en formato SQLite son muy comunes tanto en sistemas Android como en sistemas iOS y nos permiten obtener información muy relevante sobre las aplicaciones, el dispositivo y el uso que se le ha dado.

Algunas de las bases de datos más interesantes desde el punto de vista forense en terminales iOS son:



© Universidad Internacional de La Rioja (UNIR)

| Ubicación | Aplicación |
|---|---|
| /var/mobile/Library/SMS/sms.db | SMS |
| /var/mobile/Library/Accounts/Accounts3.sqlite | Cuentas del usuario |
| /var/mobile/Library/Notes/notes.sqlite | Notas |
| Applications/com.google.GoogleMobile/Library/GoogleMobile/searchhistory.db | Historial de búsqueda de Google |
| /var/mobile/Library/Calendar/Calendar.sqlitedb | Calendario |
| /var/mobile/Library/Mail/Recents | Correos recientes |
| /var/wireless/Library/CallHistory/call_history.db | Registro de llamadas |
| /var/mobile/Library/Voicemail/voicemail.db | Mensajes de voz |

Tabla 1. Bases de datos interesantes para los forenses. Fuente: elaboración propia.

Además, los dispositivos iOS (al igual que los basados en MacOS) hacen uso de los conocidos archivos Plist (Property list) para guardar información de las aplicaciones. Estos archivos almacenan información en forma de «clave – valor», y esta puede ser almacenada en formato binario (BPlist) o XML (Plist).

El uso más común de estos archivos es almacenar las preferencias del usuario, pero también podemos encontrar información relevante como tokens de inicio de sesión, contraseñas o información sobre archivos de manera similar a los metadatos (ejemplo, información sobre las partes de una grabación de audio).

Para visualizar estos archivos, podemos utilizar cualquier editor de texto plano (en el caso de Plist en formato XML) o herramientas específicas como: **Plist Explorer, PlistEdit Pro o Plist Pad.**

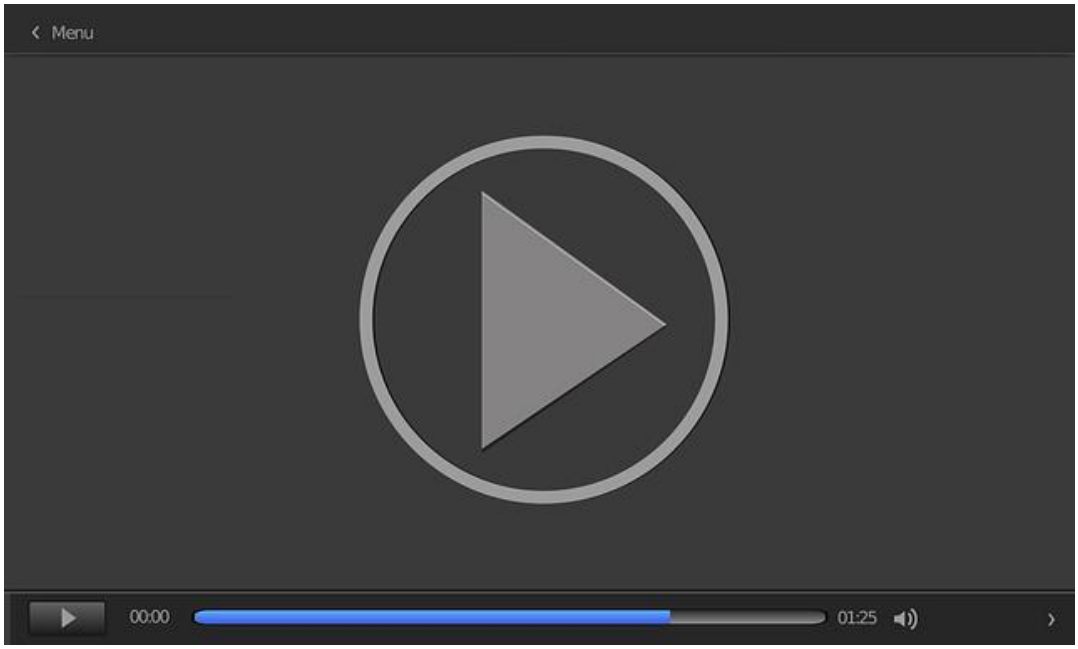
A modo de ejemplo, podemos analizar el archivo Plist que contine las últimas búsquedas realizadas con el explorador Safari en la ruta: «Library/Caches/Safari/RecentSearches.plist».


© Universidad Internacional de La Rioja (UNIR)

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE plist PUBLIC "-//Apple//DTD PLIST 1.0//EN"
"http://www.apple.com/DTDs/PropertyList-1.0.dtd">
<plist version="1.0">
<dict>
      <key>RecentSearches</key>
      <array>
            <string>corvette emergency brake line diagram
</string>
            <string>who won the debate</string>
      </array>
</dict>
</plist>
```

Figura 10. Archivo RecentSearches.plist. Fuente: elaboración propia.

En el siguiente vídeo, hablaremos sobre Magnent Acquire:




Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=e0138f68-2bc1-476c-950b-b19c00b36b42



© Universidad Internacional de La Rioja (UNIR)

## 8.5. Referencias bibliográficas

Tamma, R. (2020). *Practical Mobile Forensics: Forensically investigate and analyze iOS, Android, and Windows 10 devices.* Packt Publishing.

Skulkin, O., Tindall, D., Tamma, R. (2018). *Learning Android Forensics: Analyze Android devices with the latest forensic tools and techniques.* Packt Publishing.



© Universidad Internacional de La Rioja (UNIR)

## DFIR Advanced Smartphone Forensics - Poster

SANS. (25 marzo de 2021). DFIR Advanced Smartphone Forensics - Poster. https://www.sans.org/posters/dfir-advanced-smartphone-forensics/

Póster publicado por SANS sobre elementos de interés cuando analizamos dispositivos móviles.


© Universidad Internacional de La Rioja (UNIR)

## Webinar: An Introduction to Mobile Forensics

MSAB. (2020). *Webinar: An Introduction to Mobile Forensics.* [Vídeo]. YouTube. https://www.youtube.com/watch?v=5e5KdbY-xzE

Durante esta hora, se le guiará a través de una completa introducción al campo de la criminalística móvil, y se discutirá por qué los dispositivos móviles son tan relevantes en la sociedad actual.


© Universidad Internacional de La Rioja (UNIR)

# Test

**1.** Cuando vamos a realizar la adquisición de un dispositivo móvil el procedimiento a seguir es:

A. Adquirir la tarjeta del operador, la tarjeta de memoria (si dispone de ella) y la memoria del terminal.

B. Adquirir la tarjeta del operador y la memoria del terminal

C. Adquirir la tarjeta de memoria (si dispone de ella) y la memoria del terminal

D. Ninguna de las anteriores es correcta.

**2.** Algunas de las peculiaridades de la tarjeta SIM son:

A. Dispone de poca capacidad de almacenamiento.

B. Puede contener contactos.

C. Puede contener registros de llamadas y mensajes.

D. Todas las anteriores son correctas.

**3.** Para adquirir la tarjeta SIM (no virtual) de un terminal, necesitaremos:

A. Un lector de tarjetas SIM.

B. Un software de adquisición.

C. El código PIN o PUK de la tarjeta.

D. Todas las anteriores son correctas.

**4.** En la tarjeta de memoria podemos encontrar:

A. Archivos multimedia (fotografías, vídeos, música, etc.).

B. Archivos descargados por el usuario.

C. Cachés o registros de aplicaciones.

D. Todas las anteriores son correctas.


© Universidad Internacional de La Rioja (UNIR)

**5.** Si disponemos del patrón o contraseña de desbloqueo del terminal ¿Cuál sería la opción más sencilla para realizar su adquisición?

A. Realizar un ChipOff.

B. Adquirir mediante Custom Recovery la partición de datos del usuario.

C. Realizar la adquisición mediante alguna herramienta como Magnet Acquire.

D. Ninguna de las anteriores es correcta.

**6.** ¿Podemos realizar la adquisición de un dispositivo iOS mediante ADB?

A. Si, este procedimiento de adquisición es válido tanto para iOS como para Android.

B. Si, este procedimiento de adquisición es válido para los.

C. No, este procedimiento de adquisición es solo válido para Android.

D. No, este procedimiento de adquisición no es válido para iOS ni tampoco para Android.

**7.** ¿Qué es un Custom Recovery?

A. Es un *driver* específico para dispositivos Samsung.

B. Es una herramienta de flasheo.

C. Es una distribución específica que sustituye la partición de recuperación del terminal.

D. Ninguna de las anteriores es correcta.



© Universidad Internacional de La Rioja (UNIR)

**8.** ¿Cuál de los siguientes no se considera un procedimiento avanzado de adquisición?

A. JTAG.

B. Chip Off.

C. Direct Emmc.

D. Todos las anteriores se consideran procedimientos avanzados.

**9.** Podemos utilizar la suite forense Autopsy para realizar el análisis de un dispositivo Android.

A. Verdadero, ya que dispone de un plugin específico.

B. Falso, Autopsy solo es válido para el análisis de dispositivos iOS.

C. Falso, Autopsy solo es válido para el análisis de dispositivos informáticos, no dispositivos móviles.

D. Falso, Autopsy no es válido como suite forense de análisis, solo es de adquisición.

**10.** Los archivos PLIST:

A. Almacenan información en forma de «clave – valor»

B. El uso más común de estos archivos es almacenar las preferencias del usuario

C. La información puede ser almacenada en formato binario (BPlist) o XML (Plist)

D. Todas las anteriores son correctas.



© Universidad Internacional de La Rioja (UNIR)